The Art of Invisibility

Le hacker le plus célèbre du monde vous apprend à être en sécurité à l’ère de Big Brother et du Big Data

de Kevin D. Mitnick avec Robert Vamosi (Little, Brown and Company, 2017)

Résumé complet du livre – avec des exemples concrets

Aperçu chapitre par chapitre avec techniques de confidentialité, paramètres pratiques et points à retenir

Préparé comme compagnon de lecture – et non comme substitut au texte intégral.

À propos de ce résumé

Ce document résume les 16 chapitres de The Art of Invisibility de Kevin D. Mitnick avec Robert Vamosi — un manuel pratique sur la confidentialité rédigé par un ancien pirate informatique en fuite qui a passé des années à échapper à la surveillance numérique et physique. Plutôt que d'enseigner les attaques, le livre construit un manuel basé sur un modèle de menace pour protéger les informations d'identification, les communications, la localisation, les appareils et l'identité dans un monde de collecte de données permanente.

Chaque section de chapitre ci-dessous comprend un synopsis, des techniques clés (chacune suivie d'un encadré de notes de terrain ombré avec des paramètres, des commandes ou des procédures concrets) et un encadré répertoriant les outils, services et concepts abordés. Les éléments apparaissant pour la première fois sont marqués en orange. Le livre ayant été publié en 2017, plusieurs recommandations de produits sont datées ; le cas échéant, ce résumé note l'équivalent moderne.

Le livre est organisé autour d’un postulat simple : l’invisibilité parfaite n’existe pas. La confidentialité est un processus qui consiste à augmenter le coût de la surveillance, à réduire le nombre d’endroits où les identités peuvent être liées et à supposer que la moindre erreur opérationnelle peut détruire une grande partie de la protection technique. Les techniques sont présentées pour garantir la confidentialité et la sécurité personnelles licites.

Structure du livre (4 parties, 16 chapitres)

- Partie I — Informations d'identification et communications (Ch. 1 à 4) : piratage de mots de passe et 2FA, surveillance et cryptage des e-mails, écoutes téléphoniques cellulaires, messagerie sécurisée et cryptage des appareils.
- Partie II — Navigation, suivi et hygiène du réseau (Ch. 5 à 8) : anonymat du navigateur, suivi et empreintes digitales de tiers, Wi-Fi domestique et logiciels malveillants, Wi-Fi public et VPN.
- Partie III — Métadonnées, mobilité et Internet des objets (Ch. 9 à 12) : métadonnées photographiques et reconnaissance faciale, surveillance mobile/de localisation, voitures connectées et appareils domestiques intelligents.
- Partie IV — Travail, voyages et anonymat opérationnel (Ch. 13 à 16) : surveillance du lieu de travail, fouilles aux frontières et sécurité des voyages, l'affaire Silk Road et le manuel complet de l'anonymat.

Chapitre 1 : Votre mot de passe peut être piraté !

S'ouvre avec la fuite de photos iCloud « Fappening » de 2014 pour montrer que la plupart des comptes compromis sont des attaques d'identifiants, et non des exploits exotiques : les victimes ont été ciblées via des noms d'utilisateur, des mots de passe et des réinitialisations de questions de sécurité. Mitnick explique pourquoi les mots de passe faibles ou réutilisés tombent rapidement dans des outils tels que John l'Éventreur, puis présente une défense pratique : de longues phrases secrètes uniques, un gestionnaire de mots de passe, des verrous d'appareil, un 2FA plus fort et une gestion minutieuse des questions de réinitialisation.

Techniques et exemples clés

- La longueur et le caractère unique comptent plus que des substitutions intelligentes. Une longue phrase secrète aléatoire qui n'est jamais réutilisée est bien plus difficile à déchiffrer qu'un mot de passe court « complexe ».

```
Bad:   P@ssw0rd!                 (8 chars, common pattern)
Good:  harbor-mint-78-cobalt-...  (20+ chars, random, unique)
Rule:  one secret per account; no reuse, ever.
```

- Un gestionnaire de mots de passe vous permet d'utiliser un secret aléatoire différent partout. Sa phrase secrète principale devient le point de défaillance unique, alors protégez-la avec une longue phrase secrète, 2FA et une copie de récupération hors ligne.

```
Manager:       1Password / Bitwarden / KeePassXC
Master:        20+ character passphrase, never reused
Second factor: TOTP app or hardware key on the vault
Recovery:      offline backup of vault + printed backup codes
```

- Le 2FA est essentiel mais pas égal : les codes SMS peuvent être volés par échange de carte SIM, tandis que les clés matérielles TOTP et FIDO2 basées sur les applications résistent à cette attaque. Ajoutez un code PIN d'opérateur et un gel de port, et supprimez les SMS comme chemin de récupération lorsque cela est possible.

```
Strongest: FIDO2 hardware key / passkey
Good:      TOTP authenticator app
Weakest:   SMS code (SIM-swap risk)
Carrier:   account PIN + port-out freeze
```

- Les questions de sécurité sont une porte dérobée de réinitialisation de mot de passe. Traitez-les comme un autre champ de mot de passe : stockez des réponses fausses et aléatoires dans le gestionnaire plutôt que de répondre honnêtement.

```
Q: First car?
A: 7Q-mint-Velvet-92   (random, vault-stored)
Do not use facts that are discoverable on social media.
```

- Verrouillez chaque appareil : mot de passe fort, verrouillage automatique court, biométrie uniquement pour plus de commodité et effacement à distance activé.

```
Passcode:    6+ digits or alphanumeric
Auto-lock:   immediately or 30 seconds
Remote wipe: enabled; backups encrypted
```

Outils / services couverts dans ce chapitre

Password managers (1Password, LastPass, KeePass)	John the Ripper	2FA / TOTP	Google Authenticator
YubiKey	iCloud / Apple ID	EPPB (Elcomsoft)	iBrute
Screen lock / remote wipe			

★ Nouveaux dans ce chapitre : password manager, John the Ripper, 2FA/TOTP, YubiKey, SIM swapping, EPPB, iBrute

Chapitre 2 : Qui d'autre lit votre e-mail ?

Examine comment la messagerie Web gratuite est financée par la surveillance : les fournisseurs analysent les messages stockés à des fins publicitaires et un procès contre Yahoo a comparé cette pratique à des écoutes téléphoniques illégales. Mitnick sépare le contenu des métadonnées, explique le cryptage symétrique par rapport au cryptage à clé publique et PGP, et montre comment Tor et les remailers anonymes peuvent masquer l'expéditeur. Le cas Snowden illustre à la fois la puissance du chiffrement et la difficulté opérationnelle de l'utiliser sans dérapage.

Techniques et exemples clés

- Chiffrez le contenu des messages de bout en bout avec PGP/GPG. TLS protège uniquement le saut entre vous et le serveur de messagerie ; PGP garde le corps illisible pour le fournisseur.

```
gpg --gen-key
gpg --encrypt --recipient alice@example.com note.txt
gpg --decrypt note.txt.gpg
Verify key fingerprints out-of-band before trusting a key.
```

- Les métadonnées peuvent être aussi révélatrices que le contenu : qui a envoyé un e-mail à qui, quand, à partir de quelle adresse IP et avec quel sujet. Minimisez les détails d'identification et les identités distinctes.

```
Visible to providers: From, To, Subject, Date, IP, routing headers
Practice: separate anonymous account; no personal details; Tor/VPN
```

- Les réexpéditeurs anonymes suppriment les en-têtes d'identification et peuvent retarder ou réorganiser les messages ; Tor cache l'adresse IP source. Les deux sont fragiles, alors combinez-les avec compartimentation.

```
PGP-encrypted body -> remailer chain -> recipient
Or: Tor + anonymous webmail with no personal recovery data
```

- Compartimentez les identités : ne réutilisez jamais une adresse personnelle, un numéro de téléphone, un compte de récupération ou un style d'écriture avec des identités anonymes et réelles.

```
Identity A: public/professional
Identity B: anonymous only
No shared: phone, recovery email, device, network, photo
```

Outils / services couverts dans ce chapitre

PGP / GnuPG	Tor	Anonymous remailers	Gmail / Yahoo webmail
Metadata analysis	Snowden case study		

★ Nouveaux dans ce chapitre : PGP/GnuPG, Tor, anonymous remailers, email metadata

---

Chapitre 3 : Écoutes téléphoniques 101

Explique comment les réseaux mobiles transforment les téléphones en dispositifs de suivi. Les combinés s'identifient constamment aux tours par IMSI ; les transporteurs et les capteurs IMSI peuvent trianguler la localisation, et le réseau de signalisation SS7 présente des faiblesses d'interception bien connues. Les téléphones Burner ne sont utiles que s'ils sont utilisés avec discipline, et CALEA garantit l'accès des forces de l'ordre à l'infrastructure de l'opérateur.

Techniques et exemples clés

- Supposons que l'opérateur sache où se trouve le téléphone même lorsque le GPS est désactivé : la triangulation de la tour et les enregistrements d'enregistrement sont indépendants des applications.

```
Location sources: tower ID + signal strength, Wi-Fi, GPS, Bluetooth
Phone off/airplane: reduces but does not erase carrier records
Faraday bag: blocks tower contact entirely
```

- Un graveur est un processus, pas un achat : payez en espèces, activez-le loin de chez vous, n'appelez jamais votre vrai téléphone et ne vous connectez jamais à vos comptes personnels.

```
Buy:   cash, no loyalty card, no ID-linked plan
Use:   away from home/work; never with personal accounts
Never: power on beside your everyday phone
```

- Les capteurs IMSI se font passer pour des tours de téléphonie cellulaire pour capturer des identifiants et parfois intercepter le trafic. Ils sont difficiles à détecter de manière fiable, alors protégez le contenu avec un cryptage de bout en bout plutôt que de faire confiance au réseau.

```
Possible signs (unreliable): forced 2G, battery drain, encryption downgrade
Defense: Signal/E2EE; assume metadata is collected
```

- SS7 et les mandats d'interception légale signifient que le réseau lui-même n'est pas un canal privé. Les lignes fixes nécessitent un accès physique ; les appels mobiles ne le font pas.

```
SS7:   global signalling network with legacy trust assumptions
CALEA: US carriers must enable lawful interception
```

Outils / services couverts dans ce chapitre

IMSI catcher / StingRay	SS7	CALEA	Burner phone
Faraday bag	Signal (E2EE)		

★ Nouveaux dans ce chapitre : IMSI catcher, SS7, CALEA, burner phone, Faraday bag

---

Chapitre 4 : Si vous ne chiffrez pas, vous n’êtes pas équipé

Passe de l'interception au chiffrement au repos et en mouvement. Mitnick utilise des affaires pénales pour montrer comment un téléphone déverrouillé ou des SMS non cryptés peuvent tout révéler, explique pourquoi les opérateurs conservent les SMS et compare les applications de messagerie par modèle de cryptage. Il recommande le cryptage de bout en bout avec OTR et une confidentialité de transmission parfaite, et nomme des applications telles que Signal, ChatSecure, Cryptocat, Tor Messenger et Silent Phone.

Techniques et exemples clés

- Connaître les trois modèles de messagerie : pas de chiffrement (SMS), chiffrement partiel ou côté serveur (le fournisseur détient les clés) et chiffrement de bout en bout (clés uniquement sur les points de terminaison).

```
No encryption: SMS/MMS, readable by carrier
Partial:       provider can read or hand over messages
End-to-end:    only sender and recipient devices hold keys
```

- Préférez E2EE avec un secret de transmission parfait ; vérifiez les numéros de sécurité ou les empreintes digitales et utilisez des messages qui disparaissent pour limiter l’exposition historique.

```
Signal: Safety Number changed -> re-verify out-of-band
Disappearing messages: 1 day / 1 week / custom
```

- Chiffrez également les données au repos : chiffrement complet du disque, mot de passe fort, sauvegardes chiffrées et aucun aperçu des messages sur l'écran de verrouillage.

```
Disk:     FileVault / BitLocker / LUKS
Backups:  encrypted; passphrase stored separately
Previews: off; lock screen hides message content
```

- Les SMS ne conviennent pas aux secrets : ils ne sont pas cryptés pendant le transit et sont conservés par les opérateurs, et le 2FA basé sur SMS est vulnérable à l'échange de carte SIM.

```
Sensitive chat: Signal (or another audited E2EE app)
2FA:            authenticator app or hardware key, not SMS
```

Outils / services couverts dans ce chapitre

Signal	ChatSecure	Cryptocat	Tor Messenger
Silent Phone	OTR	Perfect forward secrecy	Full-disk encryption
SMS			

★ Nouveaux dans ce chapitre : Signal, ChatSecure, Cryptocat, Tor Messenger, Silent Phone, OTR, perfect forward secrecy

---

Chapitre 5 : Maintenant tu me vois, maintenant tu ne me vois plus

Montre comment la navigation laisse des preuves et combien peu de « mode privé » se cache réellement. Les affaires fédérales contre Khairullozhon Matanov et David Kernell illustrent que l'effacement de l'histoire peut en soi devenir un crime. Mitnick couvre les avertissements HTTPS et de certificat, les autorisations de localisation, la synchronisation du navigateur, les risques de proxy, les copies dans le cloud et les moteurs de recherche respectueux de la confidentialité tels que DuckDuckGo et Startpage.

Techniques et exemples clés

- La navigation privée évite uniquement l'historique local et les cookies ; votre FAI, votre employeur, votre résolveur DNS et les sites eux-mêmes voient toujours la connexion.

```
Private window: no local history after close
Still visible:  ISP, DNS, employer, Wi-Fi operator, destination site
```

- Utilisez HTTPS partout et ne cliquez jamais sur les erreurs de certificat sur les sites sensibles ; un certificat valide authentifie le site et crypte la page.

```
Look for: https:// + valid certificate + no browser warning
Avoid:    HTTP login pages; bypassing certificate warnings
```

- Désactivez la géolocalisation par défaut, vérifiez les autorisations du site et séparez les profils de navigateur par identité. Les paramètres de synchronisation peuvent copier des données sensibles sur plusieurs appareils et dans le cloud.

```
Location: block by default; allow per-site only
Sync:     off for anonymous/sensitive profiles
Profiles: work | personal | anonymous
```

- Les moteurs de recherche suivent les surfaces ; DuckDuckGo et Startpage évitent de créer un profil de recherche, mais les associent toujours à HTTPS ou Tor lorsque l'anonymat est important.

```
DuckDuckGo / Startpage: no personal search history
Tor Browser:            hides source IP; uniform fingerprint
```

- Les proxys cachent votre adresse IP à la destination mais le proxy voit votre trafic ; les proxys gratuits sont souvent malveillants ou monétisés. Tor est plus fort mais plus lent et n'est pas une panacée.

```
Proxy: hides IP from site; proxy logs remain a risk
Tor:   layered relays; use Tor Browser, not a random proxy
```

Outils / services couverts dans ce chapitre

Private browsing (Firefox, Chrome, Safari)	HTTPS Everywhere	DuckDuckGo	Startpage
Proxies	Tor Browser	Browser profiles	

★ Nouveaux dans ce chapitre : private browsing, HTTPS Everywhere, DuckDuckGo, Startpage, Tor Browser

---

Chapitre 6 : Chaque clic de souris que vous faites, je vous surveillerai

Passe de l'historique de recherche à l'écosystème de suivi : scripts tiers, identifiants publicitaires, empreintes digitales du navigateur et opérateurs de téléphonie mobile. Les URL liées à la santé peuvent divulguer des conditions sensibles aux réseaux et aux courtiers de données, et même HTTPS ne cache pas tous les détails de la destination. Mitnick recommande des bloqueurs de scripts, des bloqueurs de trackers, des identités distinctes, des machines virtuelles et des paramètres de confidentialité.

Techniques et exemples clés

- Supposons que chaque page charge des trackers tiers ; bloquer les scripts et les trackers intersites, en acceptant que certains sites tombent en panne.

```
uBlock Origin: block ads/trackers
NoScript:     allow JavaScript selectively
Ghostery:     reveal and block trackers
```

- Les empreintes digitales du navigateur vous identifient par configuration (écran, polices, fuseau horaire, plugins, canevas) même sans cookies. Un navigateur uniforme anti-empreintes digitales constitue la défense la plus solide.

```
Tests:   browserleaks.com, Cover Your Tracks
Defense: Tor Browser; Firefox resistFingerprinting; minimize extensions
```

- Identités séparées pour éviter toute corrélation : adresses e-mail distinctes pour les achats, les réseaux sociaux et l'utilisation anonyme ; conteneurs de navigateur séparés ; une VM jetable pour les sites à risque.

```
Email:   personal | shopping | anonymous
Browser: containers/profiles per identity
VM:      disposable for untrusted downloads/sites
```

- Les opérateurs et applications mobiles vous profilent également ; limitez les autorisations de localisation et d’arrière-plan, utilisez un VPN et vérifiez les paramètres d’identification publicitaire.

```
Carrier: sees metadata, DNS, some content
Defense: VPN + private DNS + minimal app permissions
```

Outils / services couverts dans ce chapitre

uBlock Origin	NoScript	Ghostery	Tor Browser
Firefox resistFingerprinting	Browser fingerprint tests	Virtual machines	Multiple email addresses
VPN			

★ Nouveaux dans ce chapitre : NoScript, Ghostery, uBlock Origin, browser fingerprinting, virtual machine

---

Chapitre 7 : Payer ou autrement !

Utilise l'affaire Barry Ardolf – un attaquant a utilisé le Wi-Fi non sécurisé d'un voisin et le FBI a perquisitionné le voisin innocent – pour affirmer que la sécurité du réseau domestique est une question de sécurité publique. Mitnick couvre les paramètres par défaut du routeur, WPA2 par rapport à WEP, les mises à jour du micrologiciel, la liste blanche MAC, le phishing, les ransomwares et les protections physiques telles que les couvertures de webcam.

Techniques et exemples clés

- Renforcez d'abord le routeur : modifiez le mot de passe administrateur et le SSID, désactivez le WPS et la gestion à distance, mettez à jour le micrologiciel et utilisez WPA2-AES ou WPA3.

```
Admin:   unique password, not the ISP default
Wi-Fi:   WPA2-AES / WPA3; long random passphrase
Disable: WPS, UPnP, remote admin
Update:  router firmware automatically where possible
```

- Segmentez le réseau : placez les visiteurs et les appareils IoT sur un réseau invité isolé afin qu'un appareil compromis ne puisse pas atteindre vos ordinateurs portables ou NAS.

```
Guest SSID: internet-only, client isolation on
IoT:        guest/VLAN, no access to trusted LAN
```

- Le phishing et les ransomwares sont les principales voies d'accès aux logiciels malveillants ; vérifiez les pièces jointes et les liens inattendus, appliquez les correctifs rapidement et conservez une sauvegarde hors ligne ou immuable.

```
Backup: 3-2-1 rule, one copy offline
Email:  no macros; hover links; verify sender out-of-band
```

- Questions de sécurité physique : couvrez les webcams, verrouillez les écrans et vérifiez la liste des appareils connectés au routeur pour détecter les clients inconnus.

```
Webcam: sliding cover
Router: client list; MAC filtering (weak, but raises the bar)
```

Outils / services couverts dans ce chapitre

Router admin panel	WPA2 / WPA3	MAC filtering	Firmware updates
Antivirus	Encrypted backups	Webcam cover	

★ Nouveaux dans ce chapitre : WPA2/WPA3, MAC filtering, ransomware, router firmware

---

Chapitre 8 : Croyez tout, ne faites confiance à rien

Se concentre sur les réseaux publics. Une expérience de sécurité finlandaise a montré avec quelle facilité les gens rejoignent le Wi-Fi ouvert et acceptent des conditions absurdes ; les appareils peuvent également se connecter automatiquement à des points d'accès malveillants. Mitnick recommande de traiter le Wi-Fi ouvert comme hostile, de désactiver la connexion automatique, d'utiliser un réseau cellulaire ou un point d'accès personnel, de choisir un VPN digne de confiance et de suivre une hygiène stricte sur les ordinateurs publics.

Techniques et exemples clés

- Traitez chaque réseau ouvert comme non fiable : désactivez la connexion automatique, oubliez les anciens SSID et évitez les opérations bancaires ou les connexions sensibles sur le Wi-Fi public.

```
Auto-join: off
Known networks: forget old public SSIDs
Sensitive tasks: cellular or personal hotspot only
```

- Un VPN crypte le trafic entre vous et le fournisseur VPN ; cela déplace la confiance plutôt que de l'éliminer. Choisissez un fournisseur audité, sans journaux, avec PFS et une juridiction claire.

```
Check: logging policy, PFS, audits, jurisdiction, ownership
Avoid: free VPNs with unclear funding/ownership
```

- HTTPS est toujours important sur les réseaux publics ; vérifiez les certificats et ne saisissez jamais d'informations d'identification via un portail captif.

```
Captive portal: no sensitive login until you trust the path
Site: HTTPS + valid cert; no warnings
```

- Les ordinateurs publics sont supposés compromis : utilisez uniquement un compte graveur, activez 2FA, déconnectez-vous, effacez l'historique et les téléchargements, et redémarrez si possible.

```
Use:   no personal accounts
After: log out, clear data, restart
```

Outils / services couverts dans ce chapitre

VPN	Personal hotspot	Cellular data	HTTPS
2FA	Burner device	Public terminal	

★ Nouveaux dans ce chapitre : VPN, personal hotspot, burner device

---

Chapitre 9 : Vous n'avez aucune vie privée ? Surmontez-le !

Explorez les métadonnées et le mythe selon lequel la suppression d'une publication la rend privée. Une photo publiée lors de la recherche de John McAfee a révélé sa localisation via EXIF ; un selfie djihadiste et l'activité d'El Chapo sur les réseaux sociaux ont également divulgué des détails opérationnels. Mitnick couvre également la recherche sur la reconnaissance faciale, les licences de contenu étendues des plateformes sociales et la difficulté de véritablement supprimer des données.

Techniques et exemples clés

- Les photos contiennent des métadonnées EXIF : GPS, appareil, horodatage. Supprimez-le avant de publier ou désactivez la géolocalisation au niveau de la caméra ou de l'application.

```
exiftool -gps:all= -overwrite_original photo.jpg
Check: GPS, camera serial, timestamps, software
```

- Les publications révèlent l'emplacement, la routine et les associations même sans GPS ; retarder la publication, désactiver la localisation précise et éviter les arrière-plans identifiables.

```
Disable: location tagging
Delay:   post after leaving the location
Audience: friends/custom; review old public posts
```

- La reconnaissance faciale peut lier un visage à un nom, un profil et parfois des identifiants sensibles ; supposez que les photos publiques peuvent être récupérées et comparées.

```
Limit: tagged photos, public albums, face-recognition settings
Audit: search your name/image periodically
```

- Les plateformes sociales peuvent conserver de larges licences sur votre contenu, et la suppression n'est pas garantie ; minimisez les téléchargements et lisez les conditions avant de faire confiance à un bouton « supprimer ».

```
Assume: once uploaded, copies persist (caches, backups, scrapers)
```

Outils / services couverts dans ce chapitre

EXIF / ExifTool	Social privacy settings	Facial recognition	Metadata viewers

★ Nouveaux dans ce chapitre : EXIF, ExifTool, facial recognition, photo metadata

---

Chapitre 10 : Vous pouvez courir mais pas vous cacher

Documente la manière dont les téléphones, les appareils portables, les drones et les détaillants surveillent l'emplacement. Le politicien allemand Malte Spitz a obtenu des dossiers de transporteur montrant 85 000 points de localisation en six mois ; la désactivation du GPS n'arrête pas le suivi de la tour. Mitnick couvre l'historique de localisation de Google et d'Apple, les trackers de fitness, les drones, la reconnaissance faciale au détail et les capteurs IMSI, exhortant les lecteurs à auditer et à purger les données de localisation.

Techniques et exemples clés

- Les enregistrements de localisation des transporteurs existent indépendamment du GPS et des applications ; pour les réunions sensibles, laissez le téléphone derrière vous ou utilisez un sac Faraday.

```
Sources: tower triangulation, Wi-Fi, GPS, Bluetooth
Defense: leave phone; Faraday bag; minimal carriage
```

- Auditez et réduisez l'historique de localisation de la plate-forme : désactivez l'historique des positions Google et les emplacements importants Apple, définissez la suppression automatique et examinez les autorisations par application.

```
Google: Location History off; auto-delete 3 months
Apple:  Settings > Privacy > Location Services > System Services
        > Significant Locations > Clear History / off
```

- Les appareils portables et intelligents créent des ensembles de données d'activité et de localisation intimes ; désactivez la synchronisation GPS et cloud lorsque cela est possible et vérifiez les paramètres de confidentialité.

```
Fitness tracker: GPS off, privacy zones, local sync
Health data:     limit third-party app access
```

- Supposons des caméras et des capteurs dans les magasins, les drones et les espaces publics ; minimisez les données de fidélité, payez en espèces lorsque cela est possible et ne comptez pas sur le Wi-Fi « anonyme ».

```
Retail: cash, no loyalty card, no store Wi-Fi
```

Outils / services couverts dans ce chapitre

Carrier records	Google Location History	Apple Significant Locations	Fitness trackers
Drones	Retail facial recognition	IMSI catchers	

★ Nouveaux dans ce chapitre : Google Location History, Apple Significant Locations, fitness trackers, drones

---

Chapitre 11 : Hé, KITT, ne partage pas ma position

Se tourne vers les voitures connectées. Les chercheurs Charlie Miller et Chris Valasek ont ■■piraté à distance une Jeep Cherokee, provoquant le rappel de 1,4 million de véhicules et un débat sur la cybersécurité automobile. Mitnick examine également les données de covoiturage, les cartes de transport en commun traçables, les lecteurs de plaques d'immatriculation, l'infodivertissement des voitures de location, la télémétrie Tesla, les systèmes de véhicule à véhicule et les voitures autonomes.

Techniques et exemples clés

- Une voiture connectée est une plateforme de collecte de données : la télématique, le GPS, les téléphones couplés et les comptes d'applications enregistrent les itinéraires et les comportements. Vérifiez les paramètres de partage et appliquez des rappels de sécurité.

```
Connected services: review privacy/data-sharing settings
Software: apply recalls and updates promptly
```

- Les voitures de location et les systèmes d'infodivertissement conservent les données ; évitez de coupler un téléphone personnel et supprimez les couplages, les contacts et les destinations avant de restituer la voiture.

```
Before return: remove phone pairing, contacts, nav history
Assume: previous renters' data may still be present
```

- Les comptes de covoiturage et de transport en commun lient les voyages à l'identité ; les données peuvent survivre à la suppression du compte et les cartes de transport sans contact sont traçables.

```
Uber/Lyft: assume trip history retained
Transit:   cash ticket vs registered NFC card
```

- Les lecteurs de plaques d'immatriculation et les systèmes V2V/auto-conduite rendent les mouvements reconstructibles ; il n'y a pas de simple désabonnement, alors minimisez les autres identifiants.

```
ALPR: assume every plate read is logged and shared
```

Outils / services couverts dans ce chapitre

Uconnect	Uber / Lyft	NFC transit cards	ALPR
Tesla	CarPlay / Android Auto	V2V	

★ Nouveaux dans ce chapitre : Uconnect, Uber/Lyft, NFC transit cards, ALPR, Tesla, V2V

Chapitre 12 : L'Internet de la surveillance

Examine l'Internet des objets via les thermostats Nest, un hub Insteon qu'un chercheur contrôlait à des centaines de kilomètres de distance, et le botnet Mirai, qui a enrôlé des caméras et des routeurs non sécurisés dans des attaques DDoS massives. La leçon : les appareils pratiques sont livrés avec des paramètres par défaut faibles, sont rarement corrigés et peuvent exposer à la fois les foyers et l'Internet au sens large.

Techniques et exemples clés

- Modifiez les informations d'identification par défaut et maintenez le micrologiciel à jour ; isolez les appareils IoT sur un réseau invité ou un VLAN afin qu'une compromission ne puisse pas atteindre les appareils de confiance.

```
Each device: unique password, auto-update on
Network:     guest SSID/VLAN with client isolation
```

- Supposons que les caméras, les microphones et les babyphones soient accessibles à distance ; utilisez des volets physiques, des mots de passe uniques forts et 2FA lorsqu'ils sont disponibles.

```
Camera: physical cover when not in use
Mic:    mute/disable voice assistant; review cloud recordings
```

- Les appareils IoT non sécurisés deviennent membres du botnet (Mirai) ; retirez les appareils qui ne reçoivent plus de mises à jour de sécurité et recherchez les services exposés.

```
Retire:   no firmware support -> replace
Exposure: disable remote access/port forwarding when unnecessary
```

- Les appareils intelligents envoient des données télémétriques aux fournisseurs ; privilégiez le traitement local et examinez ce qui est stocké dans le cloud.

```
Prefer: local control, no mandatory cloud
Review: retention, sharing, law-enforcement access policies
```

Outils / services couverts dans ce chapitre

Nest	Insteon	Mirai	Smart TVs
Baby monitors	Guest network / VLAN	Firmware updates	

★ Nouveaux dans ce chapitre : Nest, Insteon, Mirai, IoT botnet

---

Chapitre 13 : Choses que votre patron ne veut pas que vous sachiez

Regarde la surveillance au travail. Les employeurs peuvent surveiller le GPS, les frappes au clavier, les e-mails, le calendrier et le trafic réseau et, dans de nombreuses juridictions, ils n'ont pas besoin d'en informer les employés. Mitnick recommande de verrouiller les écrans, de séparer le travail et la vie personnelle, de se méfier des imprimantes et des téléphones VoIP et de crypter les données avant le téléchargement dans le cloud.

Techniques et exemples clés

- Supposons que les appareils de travail et les réseaux soient surveillés ; effectuez vos affaires personnelles sur des appareils personnels et des données cellulaires, jamais sur le réseau local de l'entreprise.

```
Work laptop: work only
Personal:    personal phone + cellular data
```

- Verrouillez votre écran chaque fois que vous partez et sécurisez les documents physiques ; les imprimantes et les copieurs conservent les copies, utilisez donc une impression/un code PIN sécurisé et récupérez-les immédiatement.

```
Lock:  Win+L / Ctrl+Cmd+Q
Print: secure print, collect immediately, clear jobs
```

- Les appareils de bureau tels que les téléphones VoIP et les imprimantes peuvent être compromis ; garder le micrologiciel à jour et le segmenter des systèmes sensibles.

```
VoIP:    separate VLAN, strong admin password, updates
Printer: disable unused services, wipe before disposal
```

- Le stockage cloud n'est pas automatiquement privé ; cryptez les fichiers sensibles côté client avant de les télécharger et comprenez qui peut accéder au compte.

```
Encrypt: Cryptomator / VeraCrypt container
Cloud:   assume provider/law enforcement can access unencrypted data
```

Outils / services couverts dans ce chapitre

GPS trackers	Keyloggers	Email/calendar monitoring	Office printers
VoIP phones	Cloud storage	Cryptomator / VeraCrypt	

★ Nouveaux dans ce chapitre : keylogger, VoIP, printer retention, Cryptomator

---

Chapitre 14 : Obtenir l’anonymat est un travail difficile

Un chapitre sur la sécurité des voyages construit autour de la détention de l’auteur et de la fouille de son appareil à l’aéroport d’Atlanta. Le CBP et l'ICE peuvent fouiller les appareils à la frontière ; Mitnick recommande de voyager avec des données propres et minimales, de tout chiffrer, d'utiliser des volumes cachés, des emballages inviolables, de redémarrer les iPhones pour désactiver Touch ID, Tails et Tor, les VPN et les méthodes de paiement anonymes.

Techniques et exemples clés

- Voyagez avec moins : utilisez un appareil propre, laissez les données sensibles à la maison ou dans une sauvegarde cloud cryptée et emportez uniquement ce dont le voyage a besoin.

```
Travel device: clean OS, no personal accounts
Data:          encrypted backup at home; minimal local files
```

- Chiffrez au repos avec une phrase secrète forte que vous ne portez pas ; utilisez les volumes cachés VeraCrypt là où un déni plausible est approprié.

```
VeraCrypt: outer volume + hidden volume
Device:    fully powered off, not sleep, at checkpoints
```

- Hygiène aux frontières : redémarrez un iPhone avant l'inspection pour désactiver Touch ID, connaissez les lois locales sur la divulgation des codes d'accès, utilisez des sacs inviolables et gardez les appareils en vue.

```
iPhone: power off/reboot -> passcode required (Touch ID disabled)
Bag:    tamper-evident seal; verify after handling
```

- Sur la route, supposez que l’hôtel et le Wi-Fi public sont hostiles (DarkHotel) ; utilisez Tails/Tor et un VPN, usurpez les adresses MAC et évitez les paiements liés à l'identité.

```
Tails: amnesic OS, Tor by default
Wi-Fi: VPN + MAC randomization; no personal logins
Money: prepaid gift cards / cash / Bitcoin (with awareness)
```

Outils / services couverts dans ce chapitre

VeraCrypt	Tails	Tor	VPN
PGP Whole Disk Encryption	MAC changer	Tamper-evident bags	Prepaid gift cards
Bitcoin			

★ Nouveaux dans ce chapitre : VeraCrypt, Tails, MAC spoofing, tamper-evident bags, Bitcoin

---

Chapitre 15 : Le FBI trouve toujours son homme

Reconstruit la chute de Ross Ulbricht, le redoutable pirate Roberts de la Route de la Soie. Tor et le Wi-Fi de la bibliothèque publique ne l'ont pas rendu invisible : les enquêteurs ont lié son véritable courrier électronique au personnage, ont monté un dossier et l'ont arrêté alors qu'il était connecté. Mitnick utilise le cas pour expliquer les couches Web superficielles, profondes et sombres, les limites de Tor et les projets expérimentaux de dissimulation de localisation tels que ProxyHam et ProxyGambit.

Techniques et exemples clés

- L’anonymat est opérationnel, pas un seul outil : Tor a caché l’adresse IP d’Ulbricht, mais des identifiants réutilisés et des erreurs personnelles liaient le personnage à lui.

```
Tor hides: source IP
Tor does not hide: behavior, writing style, reused email/alias, timing,
                   personal accounts, physical surveillance
```

- Gardez les personnages rigoureusement séparés : appareil dédié, nouveau portefeuille de messagerie et de cryptographie, pas de connexions personnelles, pas de réseaux ou de numéros de téléphone partagés.

```
Persona: new email + wallet + device
Never:   log into personal accounts on the anonymous device
```

- Le Wi-Fi public n'est pas un bouclier ; les emplacements habituels et la surveillance physique peuvent vous identifier même lorsque le réseau est anonyme.

```
Assume: physical surveillance at regular locations
```

- Le dark web n'est pas automatiquement sûr : les services .onion offrent l'anonymat, mais les marchés attirent les agents infiltrés et les échecs de l'opérationsec.

```
Layers: surface web | deep web | dark web (.onion)
Access: Tor Browser; still requires disciplined opsec
```

Outils / services couverts dans ce chapitre

Tor	Silk Road	ProxyHam	ProxyGambit
Dark web / .onion			

★ Nouveaux dans ce chapitre : Tor, Silk Road, ProxyHam, ProxyGambit, dark web

---

Chapitre 16 : Maîtriser l'art de l'invisibilité

La pierre angulaire : une identité anonyme étape par étape. Mitnick couvre l'achat d'un ordinateur portable dédié en espèces, l'utilisation de Tails et Tor, le fait de garder l'appareil loin de la maison, l'achat de cartes prépayées par l'intermédiaire d'un tiers, la modification des adresses MAC, l'utilisation d'un point d'accès anonyme, la création de comptes ProtonMail ou Tutanota sur Tor et la conversion des cartes-cadeaux en Bitcoin. Il termine en avertissant que le comportement – ■■modèles de frappe, choix de mots, habitudes – peut mettre en échec l'anonymat technique.

Techniques et exemples clés

- Construisez un kit anonyme dédié : un ordinateur portable propre acheté en espèces, Tails sur USB, pas de compte personnel, utilisé uniquement hors de chez vous.

```
Laptop: cash, no registration/loyalty link
OS:     Tails from USB
Use:    cafe/library/public network away from home
```

- Créez une nouvelle identité sans chevauchement : e-mail anonyme sur Tor, un portefeuille crypto distinct et aucune information personnelle ni photo.

```
Email: ProtonMail / Tutanota over Tor
Money: gift cards -> Bitcoin (understand traceability)
```

- Hygiène du réseau : modifiez ou usurpez l'adresse MAC à chaque session et utilisez un point d'accès portable acheté anonymement au lieu du Wi-Fi public.

```
MAC:     randomize per connection
Hotspot: prepaid, cash, never powered on at home
```

- Le comportement est la fuite finale : le rythme de frappe, le vocabulaire, l'emploi du temps et les erreurs peuvent corréler les identités. Maintenez la personnalité de manière cohérente et vérifiez la contamination croisée.

```
Audit:    no personal logins, no home IP, no cross-device charging
Behavior: consistent persona; avoid personal idioms/habits
```

Outils / services couverts dans ce chapitre

Tails	Tor	ProtonMail	Tutanota
MAC changer	Prepaid hotspot	Bitcoin	VeraCrypt

★ Nouveaux dans ce chapitre : Tails, ProtonMail, Tutanota, MAC changer, prepaid hotspot, Bitcoin

---

Index principal des outils et techniques (par première apparition)

Les conseils du livre couvrent les informations d’identification, les communications, les réseaux, les appareils et les habitudes opérationnelles. Le tableau ci-dessous regroupe les principaux outils et techniques par chapitre où ils sont introduits pour la première fois.

Catégorie	Ch.	Outils / techniques
Identifiants et authentification	1	Password managers, John the Ripper, 2FA/TOTP, YubiKey, SIM swapping
Confidentialité et cryptage des e-mails	2–4	PGP/GnuPG, anonymous remailers, Tor, Signal, ChatSecure, OTR, PFS
Cryptage des appareils et des données	4, 14	Full-disk encryption, encrypted backups, VeraCrypt
Navigation et suivi	5–6	Private browsing, HTTPS Everywhere, DuckDuckGo, Startpage, NoScript, Ghostery, uBlock Origin, browser fingerprinting, Tor Browser
Réseaux domestiques et publics	7–8	WPA2/WPA3, MAC filtering, guest network, VPN, personal hotspot, burner device
Métadonnées et surveillance mobile	9–11	EXIF/ExifTool, facial recognition, Google Location History, Apple Significant Locations, IMSI catchers, ALPR
Appareils connectés	11–13	Uconnect, Uber/Lyft, NFC transit cards, Tesla, Nest, Insteon, Mirai, keyloggers, VoIP, Cryptomator
Voyages et anonymat	14–16	Tails, Tor, VPN, MAC spoofing, tamper-evident bags, prepaid gift cards, Bitcoin, ProtonMail, Tutanota, ProxyHam/ProxyGambit

La liste de contrôle de l’invisibilité

1. **Utilisez une phrase secrète longue et unique pour chaque compte, stockée dans un gestionnaire de mots de passe ; protégez le coffre-fort avec une phrase secrète solide et une clé matérielle ou TOTP 2FA.**
2. **Séparez les identités par objectif et ne partagez jamais de numéros de téléphone, d'adresses de récupération, d'appareils ou de méthodes de paiement entre eux.**
3. **Chiffrez les messages sensibles de bout en bout et chiffrez les données au repos ; conserver des sauvegardes testées et hors ligne.**
4. **Naviguez avec HTTPS, le blocage des trackers et un navigateur de confidentialité ; désactiver les autorisations de localisation par défaut.**
5. **Renforcez le routeur domestique, mettez à jour le micrologiciel et isolez l'IoT et les invités sur un réseau distinct.**
6. **Traitez le Wi-Fi public comme hostile ; préférez le cellulaire ou un point d’accès personnel et un VPN réputé.**
7. **Supprimez les métadonnées des photos, limitez le partage sur les réseaux sociaux et supposez que les images publiques peuvent correspondre aux visages.**
8. **Auditer et purger l'historique des emplacements ; laissez le téléphone derrière vous pour les réunions sensibles.**
9. **Revoir le partage de données sur les voitures connectées et les appareils intelligents ; Corrigez ou retirez les appareils non pris en charge.**
10. **Pour un anonymat à haut risque, utilisez du matériel distinct, des achats en espèces, des Tails/Tor, des changements MAC et une discipline comportementale continue.**

Notes finales

L'Art de l'Invisibilité est un manuel de confidentialité basé sur un modèle de menace, et non un didacticiel de piratage. Sa leçon durable est que la confidentialité est un processus : connaissez votre adversaire, réduisez votre surface d'attaque, compartimentez les identités et partez du principe que n'importe quelle erreur opérationnelle peut les relier. Le livre est plus fort sur les bases peu glamour : l'hygiène des mots de passe, le cryptage, la confiance du réseau, les métadonnées et le comportement humain qui déjoue les contrôles techniques.

De nombreuses recommandations de produits datent de 2017. 2FA, WPA2, Silent Phone, Cryptocat, Tor Messenger et ProxyHam basés sur SMS doivent être considérés comme des exemples historiques ; remplacez les équivalents maintenus tels que les clés de sécurité matérielles ou les mots de passe, WPA3, Signal, le navigateur Tor et un VPN sans journaux réputé. Les principes fondamentaux restent d'actualité : minimisez ce que vous exposez, vérifiez avant de faire confiance et concevez votre vie de manière à ce qu'aucun appareil, compte ou réseau ne connecte toutes vos identités.

Aucun livre ne peut vous rendre parfaitement invisible. L'objectif réaliste est de rendre la surveillance coûteuse, peu fiable et bruyante – et de comprendre les compromis que vous acceptez chaque fois que vous choisissez la commodité plutôt que la confidentialité.